

VetAI — Expected Questions

الأسئلة المتوقعة عن الـ AI — وإجاباتها

Twenty-six questions an examiner is likely to ask about the agentic AI layer, answered in English and Arabic, with the evidence behind each one.

Every answer verified against backend/src/ai/ · 2025 / 2026

How to use this

- The green box is the **short answer** — say that first, then stop. Let them ask for more.
- The two panes are the same answer in English and Arabic. Use whichever the question came in.
- **Evidence** lines are for if they push. Don't lead with them.
- Amber boxes flag a **trap** — a follow-up that catches people out.
- If you don't know: say so, say what you'd check, and move on. That reads better than guessing.

المربّع الأخضر هو الإجابة القصيرة — قولها الأول وبس. سيبتهم هما اللي يسألوا أكثر. الجزء الأصفر بيحدّر من سؤال متابعة بيوقع ناس كثير. ولو مش عارف الإجابة، قول كده وقول هتتأكد إزاي — ده أحسن بكثير من التخمين.

Why it is built this way

ليه اتبنى بالشكل ده

01 What makes this "agentic" and not just a chatbot?

ليه اللي يخليه agentic مش مجرد chatbot؟

SHORT ANSWER

A chatbot describes the booking. Ours writes it to the database.

EN

It calls real, typed tools that change real state — it can create an account, register a pet, find a vet with genuine open slots, and write the appointment, all inside one conversation with no forms in between. Ten tools, every argument validated by a schema.

AR

بينادي tools حقيقية بتغيّر حاجات فعلية — يقدر يعمل حساب، ويسجل حيوان، ويلاقي دكتور عنده مواعيد فاضية فعلاً، ويكتب الحجز — كل ده في محادثة واحدة من غير أي form. عشر tools، وكل argument متحقق منه بـ schema.

Evidence: `backend/src/ai/tools.js` — 10 tools, Zod schemas, 42 contract assertions.

02 Why not let the model orchestrate everything?

ليه ما تسيبوش ال model يدير كل حاجة؟

SHORT ANSWER

Because we wanted it to work the same way on a small local model as on a large hosted one.

EN

Booking is a deterministic server-side state machine. The model is asked for one narrow thing per turn — pull a name, a date, a pet out of free text — as a single JSON call. Small models chain several tool calls unreliably; extracting one field is something they do well. So the flow behaves identically whether we run Groq or a local Ollama model.

AR

الحجز نفسه state machine على السيرفر. ال model بنطلب منه حاجة واحدة ضيقة كل دور — يطلع اسم أو تاريخ أو حيوان من كلام حر — في JSON call واحد. الموديلات الصغيرة بتفشل في ربط أكثر من tool ورا بعض، بس بتطلع حقل واحد كويس جدًا. فالنتيجة إن الحجز بيشتغل بنفس الشكل سواء على Groq أو Ollama محلي.

Evidence: `ai/bookingFlow.js` — regex extraction wins over the model when both produce a value.

03 How much of a message is actually handled by AI?

قد إيه من الرسالة بيتعامل معاها ال AI فعلاً؟

SHORT ANSWER

Eight stages. The model runs in one of them.

EN

Language lock, safety guardrails, intent routing, the booking state machine, the concurrency gate, retrieval, the agentic loop, output screening. Six never call a model. One uses it to read a single field. One is the model.

AR

تحديد اللغة، ال safety guardrails، توجيه النية، ال state machine بتاع الحجز، ال concurrency gate، الاسترجاع، ال agentic loop، وفحص المخرجات. ستة منهم عمرهم ما بينادوا ال model، وواحدة بتستخدمه لقراءة حقل واحد، وواحدة هي ال model نفسه.

Number to quote: deterministic path $\approx$ 330 ms and 0 tokens; model path 8–18 s and $\approx$ 1,900 tokens.

Safety

الأمان

04 How do you stop it giving dangerous medical advice?

إزاي بتمنعوه إنه يدي نصيحة طبية خطر؟

SHORT ANSWER

We never gave it that job. The safety check runs before the model, and screens it again afterwards.

EN

Three detectors run on the raw message — emergency, urgent symptoms, toxic medication. If one fires, a fixed answer is returned and the model is never called. On the way out, a second independent screen blocks a dose, a dangerous home remedy, or a leaked system prompt.

AR

ثلاث كواشف بتشتغل على الرسالة الخام — طوارئ، أعراض عاجلة، وأدوية سامة. لو واحد منهم اشتغل، بيترجع رد ثابت وال model ما بيتناداش أصلاً. وفي الخروج، فيه فحص ثاني مستقل بيمنع أي جرعة أو وصفة منزلية خطيرة أو تسريب للـ system prompt.

Trap — "so it's just a regex?" Yes, deliberately. A regex answers in the same milliseconds every time. A model can be slow, rate-limited, or argued out of a position. For the one decision that must never fail, we wanted a rule, not a judgement.

05 Isn't a pattern match less capable than a model?

مش ال pattern match أضعف من ال model؟

SHORT ANSWER

For open questions, yes — that's what the model is for. For "is this an emergency", we want a rule.

EN

The patterns are precise rather than broad: a poisoning match needs an ingestion verb *near* the toxin, so "what human foods are toxic to dogs?" is a question, not an emergency. The model still answers everything the detectors don't claim.

AR

الأنماط مكتوبة بدقة مش بعمومية: التسمم لازم يكون فيه فعل ابتلاع قريب من المادة، علشان كده «إيه الأكل السام للكلاب؟» بيتعامل معاه كسؤال مش كطوارئ. وال model بيجاب كل اللي الكواشف مش ماسكاه.

06 Does it work in Arabic as well as English?

بيشتغل بالعربي زي الإنجليزي؟

SHORT ANSWER

Yes — and the guardrails are written for Arabic too, including the feminine verb forms.

EN

Language is decided server-side from the script itself, never guessed by the model. Arabic verbs are gendered, so a pattern written only in the masculine form silently fails on the feminine one — the test suite checks both forms of each phrase specifically.

AR

اللغة بتتحدّد على السيرفر من الحروف نفسها، مش بتخمين ال model. والأفعال العربية مذكّر ومؤنّث، فالنمط المكتوب بالمذكّر بس بيفشل بصمت مع المؤنّث — والاختبارات بتتأكد من الصيغتين لكل جملة.

Strong detail to offer: `\d` does not match Arabic-Indic numerals, so a dose written ٥٠٠ would have slipped through a filter built on it. The character class used is `[٠-٩٠-٠]`.

07 What if someone jailbreaks it?

لو حد عمل jailbreak؟

SHORT ANSWER

Then it still cannot book, cannot act as you, and its reply is still screened on the way out.

EN

A jailbreak changes what the model says, not what it can do. Write-capable tools are never handed to the free-form path. Identity comes from the JWT. Emergency detection already ran. And the output screen catches a dose or a prompt leak regardless of why it appeared.

AR

ال jailbreak بيغيّر اللي ال model بيقوله، مش اللي يقدر يعمل. ال tools اللي بتكتب مش بتتسلّم له أصلاً. والهويّة جايّة من ال JWT. وكشف الطوارئ اشتغل خلاص. وفحص المخرجات بيمسك الجرعة أو التسريب مهما كان السبب.

Model choice and cost

اختيار الموديل والتكلفة

08 Why not OpenAI or Gemini?

ليه مش OpenAI أو Gemini؟

SHORT ANSWER

We started on paid OpenAI and moved off it deliberately. There is no paid model API anywhere in the system now.

EN

Open-weight models on Groq are sufficient for this workload and give us two things a paid API doesn't: zero recurring cost, and a provider swappable by one environment variable — Groq, Ollama, or a mock. The whole test suite runs on the mock with no key and no network call.

AR

الموديلات مفتوحة الأوزان على Groq كافية للشغل ده، وبتدينا حاجتين مش موجودين في ال API المدفوع: صفر تكلفة متكررة، ومزود بيتبدل بمتغير واحد — Groq أو Ollama أو mock. وكل الاختبارات بتشتغل على ال mock من غير أي مفتاح ولا اتصال بالإنترنت.

Production model: openai/gpt-oss-20b on Groq. **Local:** hermes3 on Ollama.

09 What does it cost to run?

تكلفة التشغيل كام؟

SHORT ANSWER

EGP 0 on model inference.

EN

Groq's free tier in production, Ollama locally, a mock in CI. The concurrency gate exists precisely because that free budget is shared account-wide and has to be rationed rather than exceeded.

AR

الطبقة المجانية من Groq في الإنتاج، و Ollama محليًا، و mock في ال CI. وال concurrency gate موجود بالظبط لأن الميزانية المجانية دي مشتركة على الحساب كله ولازم تنقسم مش تتعدى.

10 What happens if Groq goes down or changes its models?

لو Groq وقع أو غير موديلاته؟

SHORT ANSWER

One environment variable moves us. It has already happened once.

EN

The client is provider-agnostic behind an OpenAI-compatible interface. Groq deprecated our original default model mid-project and the change was a one-line configuration edit. A hung provider is also bounded by a 90-second abort.

AR

ال client مش مرتبط بمزود معين — واجهة متوافقة مع OpenAI. Groq أوقفت الموديل الافتراضي بتاعنا في نص المشروع، والتغيير كان سطر واحد في الإعدادات. وكمان أي تعليق من المزود محدود بـ 90 second abort.

Accuracy and hallucination

الدقة والهلوسة

11 How do you stop it inventing answers?

إزاي بتمنعه يخترع إجابات؟

SHORT ANSWER

Health answers are retrieved first, and it is allowed to say "I don't know".

EN

Retrieval runs before generation — pgvector cosine similarity over a curated veterinary knowledge base, with a keyword fallback, matched on the pet's species. If nothing scores well enough, the service returns nothing rather than the closest partial match.

AR

الاسترجاع بيشتغل قبل التوليد — بحث pgvector قاعدة معرفة بيطرية منسقة، ومعه fallback بالكلمات المفتاحية، ومتطابق مع نوع الحيوان. ولو مفيش حاجة بدرجة كافية، الخدمة بترجع ولا حاجة بدل أقرب نتيجة جزئية.

Why that matters: a "best effort" answer to a question the knowledge base cannot support is the most dangerous kind — it's fluent and wrong, and it hides the gap. Returning nothing keeps the gap visible in the logs.

12 Can it send a user to a page that doesn't exist?

ممكن يؤدي المستخدم لصفحة مش موجودة؟

SHORT ANSWER

No — and that's enforced by a test, not by a prompt.

EN

Every route the AI may emit is declared once, and anything outside that list is refused. The test suite parses the real router file and asserts the declared list still matches it — so a hallucinated link becomes a failing build, not a 404 in front of a user.

AR

كل مسار مسموح للـ AI يرجعه معرّف في مكان واحد، وأي حاجة بزه القائمة بتترفض. والاختبارات بتقرا ملف الـ router الحقيقي وبتأكد إن القائمة لسه مطابقة — يعني اللينك المخترع بيبقى build فاشل، مش صفحة 404 قدام المستخدم.

Real bug this closed: a `/pets` route that was never real shipped and rendered the 404 page.

13 Can it claim a booking it didn't actually make?

ممکن يقول إنه حجز وهو ما حجزش؟

SHORT ANSWER

The system prompt forbids stating a vet name, fee or outcome unless a tool result in that same conversation confirmed it.

EN

And the booking itself is written by the deterministic flow, not by the model — so a confirmation the user sees corresponds to a row that exists. A database `UNIQUE` constraint on (vet, time) is the final backstop against a double booking.

AR

وكمآن الحجز نفسه بيتكتب بال `deterministic flow` مش بال `model` — يعني التأكيد اللي المستخدم شايفه بيقابله صف موجود فعلاً. وفي الآخر فيه `UNIQUE constraint` على (الطبيب، الوقت) بيمنع الحجز المزدوج.

Security of the AI layer

أمان طبقة الـ AI

14 Can the AI act as another user?

ممکن الـ AI يتصرّف باسم مستخدم تاني؟

SHORT ANSWER

No. Identity comes from the verified token and nothing in the conversation can change it.

EN

Every write authorises against a server-owned user id injected from the JWT. We also found and closed a real vulnerability here: `createAccount` used to treat an existing email as a successful sign-in, so typing a stranger's registered address bound the session to their account.

AR

كل عملية كتابة بتتحقق من هوية مملوكة للسيرفر جاية من الـ JWT. وإحنا لقينا وقفلنا ثغرة حقيقية هنا: `createAccount` كان بيتعامل مع إيميل موجود على إنه تسجيل دخول ناجح — فكتابة إيميل حد تاني كانت بتربط المحادثة بحسابه.

Be ready for: "how did you find it?" — grey-box review during the security pass, not a scanner.

15 Can the AI write to the database?

الـ AI يقدر يكتب في قاعدة البيانات؟

SHORT ANSWER

Not in free-form chat. Those tools are not in the set it is given.

EN

The chat path receives only read-only tools, filtered by an explicit allow-list in code. Writes happen inside the deterministic booking flow, which the model does not orchestrate.

AR

مسار المحادثة بياخد الـ `tools` اللي بتقرا بس، مفلتره بـ `allow-list` صريحة في الكود. والكتابة بتحصل جوة الـ `booking flow` اللي الـ `model` مش بيديره.

16 Is there an AI making security decisions?

فيه AI بياخد قرارات أمنية؟

SHORT ANSWER

No. A model may explain a block; it never makes one.

EN

A separate module triages security events the WAF already caught — after the decision, out of band. Its output is then clamped by code: a SQL-injection signature can never be downgraded below CRITICAL, abuse cannot fall below HIGH, and unparseable output fails to the severe reading, not the lenient one.

AR

فيه module منفصل بيصنّف الأحداث الأمنية اللي ال WAF مسكها خلاص — بعد القرار، وخارج المسار. ومخرجاته بعد كده بتتقيّد بالكود: توقيع ال SQL injection عمره ما ينزل تحت CRITICAL، والإساءة ما تنزلش تحت HIGH، وأي مخرج غير مقروء بيتفَسّر بالأشدّ مش بالأخف.

17 Could someone abuse the AI endpoint to burn your budget?

حد يقدر يستغل ال endpoint ويحرق ميزانيتكم؟

SHORT ANSWER

Denial of service by cost is still denial of service — so it's gated.

EN

Two concurrent model calls platform-wide, a FIFO queue, a 45-second maximum wait, and messages capped at 2,000 characters. The security-analysis endpoint, which also spends tokens, sits behind authentication, an admin check and a rate limiter, and forwards only allow-listed fields to the prompt.

AR

مكالمتين لل model في نفس الوقت على مستوى المنصة كلها، و queue بترتيب الوصول، وحد أقصى ٤٥ ثانية انتظار، والرسالة محدودة بألفين حرف. وال endpoint بتاع التحليل الأمني — اللي بيصرف tokens هو كمان — ورا authentication وفحص admin و limiter، وبيمرّر حقول مسموح بيها بس.

18 Can a user make the AI fetch a URL of their choosing?

المستخدم يقدر يخلّي ال AI يجيب لينك من اختياره؟

SHORT ANSWER

No. Photo input is restricted to our own image origin.

EN

The optional symptom photo must match our Cloudinary origin, so a caller cannot use the vision path as an SSRF primitive against internal services.

AR

صورة العرض الاختيارية لازم تكون من ال origin بتاعنا على Cloudinary، علشان محدش يستخدم مسار الرؤية ك SSRF على خدمات داخلية.

Scale, concurrency and proof

التوسّع والتزامن والإثبات

19 What was the hardest technical problem?

إيه أصعب مشكلة تقنية قابلتكم؟

SHORT ANSWER

Concurrency — twice, in two different places.

EN

First: two owners taking the last seat in a class at the same instant, solved with an explicit row lock. Second: serverless instances that cannot see each other sharing one AI token budget, solved with a semaphore inside PostgreSQL itself. Both were verified with real concurrency tests against a real database, not reasoned about on paper.

AR

الأولى: اثنين بياخدوا آخر مقعد في class في نفس اللحظة — اتحلّت بـ row lock صريح. والثانية: نسخ serverless مش شايفة بعضها وبتتشارك ميزانية tokens واحدة — اتحلّت بـ semaphore جوه PostgreSQL نفسه. والاتنين اتأكدوا باختبارات تزامن حقيقية على قاعدة بيانات فعلية، مش بالتفكير النظري.

20 Why put the queue in the database instead of memory or Redis?

ليه ال queue في قاعدة البيانات مش في الذاكرة أو Redis؟

SHORT ANSWER

In-process memory doesn't exist across serverless instances, and Redis is another service to pay for and keep alive.

EN

Postgres was already there and already gives us the one primitive we need: a row lock. One statement raises the counter and inserts the slot, and only if there is room *and* the caller is next. Two instances cannot both read "there is room" because they contend for the same row.

AR

ال Postgres موجود أصلاً، وببيدنا الحاجة الوحيدة اللي محتاجينها: row lock. جملة واحدة بترفع العدّاد وبتضيف ال slot، وبس لو فيه مكان و لو دوره جه. ومستحيل نسختين يقرأوا «فيه مكان» في نفس اللحظة لأنهم بيتزاحموا على نفس الصف.

21 What happens when the queue is full?

إيه اللي بيحصل لما ال queue تتملى؟

SHORT ANSWER

It degrades to a grounded knowledge-base answer. Busy never looks broken.

EN

A request waits at most 45 seconds — chosen to sit under the serverless function's own limit — then answers from retrieval instead of dying. A slot whose holder crashed is reclaimed after 90 seconds so a dead instance cannot shrink the gate permanently.

AR

الطلب بيستنى ٤٥ ثانية بحد أقصى — مختارة علشان تبقى تحت حد ال function نفسه — وبعدين بيجاوب من الاسترجاع بدل ما يموت. وال slot اللي صاحبه وقع بيترجع بعد ٩٠ ثانية علشان نسخة مَيّنة ما تصغّرش البوابة للأبد.

22 How do you test an AI feature?

إزاي بتختبروا feature فيها AI؟

SHORT ANSWER

By testing everything around it deterministically — and running the whole suite with no model at all.

EN

With the mock provider, 141 assertions cover the guardrails in both languages, the Arabic gender pairs, output screening and the route contract — with no key and no network call. A further 42 pin the tool set: adding a tool fails the build until its contract and coverage are updated.

AR

مع ال mock provider، فيه ١٤١ assertion بتغطي ال guardrails باللغتين، وصيغ المذكر والمؤنث، وفحص المخرجات، وعقد المسارات — من غير أي مفتاح ولا اتصال. وفيه ٤٢ كمان بتثبت مجموعة ال tools: إضافة tool بتفشّل ال build لحد ما عقدها وتغطيها يتحدّثوا.

Honest limits — say these before they ask

الحدود الصريحة — قولوها قبل ما يسألوا

23 What can't it do?

إيه اللي مش بيعرف يعملها؟

SHORT ANSWER

It doesn't diagnose, and the guardrails are a floor, not a ceiling.

EN

The detectors are pattern-based: precise and fast, and they will not catch a phrasing nobody anticipated. VetAI supports a decision — it is not a veterinarian, and the product says so, not just this document.

AR

الكواشف مبنية على أنماط: دقيقة وسريعة، ومش هتمسك صياغة محدش توقّعها. والـ VetAI بيساعد في القرار — مش دكتور بيطري، والمنتج نفسه بيقول كده مش الورقة دي بس.

24 Which tests don't run in CI?

أنهي اختبارات مش بتشتغل في الـ CI؟

SHORT ANSWER

The model-dependent ones — tool-call accuracy and prompt-injection resistance — self-skip on the mock.

EN

They need a real model, so they're run separately rather than pretended to pass. Everything deterministic does run on every push.

AR

محتاجة model حقيقي، فبتتسجل لوحدها بدل ما ندّعي إنها نجحت. وكل اللي deterministic بيتشغل مع كل push.

25 How many people actually use it?

كام حد بيستخدمه فعلاً؟

SHORT ANSWER

The platform is deployed but pre-launch. Our numbers are delivery measures, not usage.

EN

Say it plainly. Adoption is what the soft launch answers next — that's why partner onboarding sits behind feature flags an administrator flips when the first real clinic is ready.

AR

قولوها بوضوح. الانتشار هو اللي الإطلاق التجريبي هيجابو عليه — وعلشان كده ضم الشركاء وراء feature flags بيفتحها الأدمن لما أول عيادة حقيقية تبقى جاهزة.

SHORT ANSWER

Move the application off the wide-privilege database account onto a scoped role.

EN

It's the one item still open from our own security assessment, it's documented on the remediation slide, and naming it yourself is stronger than being told. After that: broaden the guardrails from patterns toward a tested classifier, with the deterministic layer kept underneath.

AR

دي الحاجة الوحيدة اللي لسه مفتوحة من التقييم الأمني بتاعنا، ومكتوبة على شريحة ال remediation، وإنكم تقولوها بنفسكم أقوى من إنهم يقولوها لكم. وبعدها: توسيع ال guardrails من الأنماط لـ classifier مُختبر، مع إبقاء الطبقة الحتمية تحتيه.